

9. Explain the purpose of mitigation techniques used to secure the enterprise

Introduction

- In this chapter, we will consider the purpose of several mitigation techniques used to secure the enterprise, including segmentation, monitoring, and encryption.

Segmentation

- Its purpose is to compartmentalize the network, creating isolated segments that restrict the lateral movement of potential attackers.
- It limits the impact of a breach, preventing cyber intruders from traversing freely across the network.
- It ensures that even if one layer is breached, the intruder is contained within a confined area, unable to access critical assets or move deeper into the network.
- The following list defines each of the major types of segmentation:

Physical segmentation

- This method separates a network into smaller segments using routers, switches, and firewalls.
- It's like building different rooms within a fortress, each with a unique access control.
- Physical segmentation is ideal for large organizations with diverse network requirements, allowing for the isolation of sensitive data and critical systems.

Virtual Local Area Networks (VLANs)

- VLANs create logical network segments within a single switch.
- VLANs are commonly used to group devices based on function or department, reducing broadcast traffic and enhancing network efficiency.

Subnetting

- Subnetting divides an IP network into smaller subnetworks, each with a subnet mask.
- Subnet segmentation simplifies network management and security by grouping devices with similar purposes or security requirements.
- This ensures efficient use of IP addresses and improves network performance.

Micro-segmentation

- Micro-segmentation takes segmentation to a granular level, applying security policies to individual workloads or devices.
- Micro-segmentation is crucial in cloud environments and data centers, where it provides fine-grained control over traffic flows, preventing lateral movement by cyber threats.

Let's look at some of the reasons for using segmentation:

Enhanced security

- Segmentation makes it harder for attackers to access sensitive data or critical systems.
- If our network had a malware attack, then using segmentation would limit the number of computers affected.

Access control

- By segmenting networks, organizations can implement access controls more effectively.
- This ensures that only authorized users or devices can access specific resources, reducing the attack surface.

Compliance requirements

- Many industries have regulations and compliance standards, such as the **PaymentCard Industry Data Security Standard (PCI DSS)**, which relates to credit card payments in a secure environment.
- Another important regulation is the **Health Insurance Portability and Accountability Act (HIPAA)**, which relates to the confidentiality, integrity, and availability of **Protected Health Information (PHI)**. This protects individuals' rights to their health information and facilitates the secure exchange of healthcare data.
- We need to segment the systems holding this data to ensure compliance.

Performance optimization

- Segmentation can lead to improved network performance by reducing broadcast domains and congestion.
- It ensures that network resources are used efficiently, enhancing the overall user experience.

Isolation of critical systems

- Organizations often have critical systems that need an extra layer of protection.
- Segmentation isolates these systems, safeguarding them from potential threats.

Scalability and agility

- Segmentation provides scalability and agility, allowing them to adapt to evolving needs without compromising security.
- If a non-segmented system is targeted by a rapidly spreading virus, it will not take long for the entire organization to be infected. However, if the same network had instead been segmented into six separate subnets, the virus could be contained to the single infected subnet, unable to spread to the rest of the system.

Access Control

- Access control refers to the process of allowing or restricting access of different parties to the organization's data, applications, network, or the cloud based on the organization's policies.
- There are two factors that are used to complete this task: the **Access Control List (ACL)** and permissions.
- ACLs are lists used by routers and firewall devices to grant or deny network traffic based on a set of rules.

Types of ACLs:

1. File System ACLs

- Define who can access files/folders and at what level.
- Example:
 - Sales Manager: Read-Only
 - Sales Administrator: Read/Write

2. Network ACLs

- Applied on routers/firewalls.
- Control network traffic using **allow/deny rules**.
- Default rule: **deny all**; add exceptions as needed.

Permissions:

- Define user actions (read, write, execute, delete).
- Based on **least privilege** principle: only grant what's necessary.

Application Allow List

Purpose:

- Approves specific applications for execution.
- Blocks unauthorized/malicious software.

Benefits:

- Prevents installation of unwanted software (e.g., games).
- Blocks malware/ransomware by allowing only vetted apps.

Use Case:

- Create a whitelist to restrict application execution across devices.
- Only listed applications are permitted; everything else is auto-blocked.

Application Block List

Purpose:

- Deny execution of specified unsafe or non-compliant apps.
- Used to mitigate risks and enforce security/compliance.

Tool Example:

- **Microsoft AppLocker:** Allows creation of block policies.

Use Cases:

- Prevent known vulnerable apps.
- Enforce compliance (e.g., disallow torrent clients).
- Improve productivity by blocking games or social media apps.

Components:

- Lists unapproved apps by name/path.
- Automatically denies execution, reducing accidental breaches.